Theoretical Knowledge and Practical Exposure - SOC

CYART – Task 4 Documentation

Prepared by: Kalash Mahajan

Date: 5th February 2026

---

1. Introduction

A Security Operations Center (SOC) is a centralized function responsible for continuously monitoring, detecting, analyzing, and responding to cybersecurity threats within an organization. Modern SOCs play a critical role in protecting systems, networks, and data by combining people, processes, and security technologies to identify malicious activity and minimize impact.

This assignment focuses on building a strong foundation in SOC fundamentals and operations, covering both theoretical concepts and practical hands-on activities. The objective is to understand how security events are generated, collected, analyzed, visualized, and responded to using industry-relevant tools and workflows. Key areas include log analysis, security monitoring, incident detection, alerting, and documentation—core responsibilities of a SOC analyst.

Through this task, a simulated SOC lab environment was created using open-source and industry-standard tools such as Elastic SIEM, Wireshark, Snort, Nessus, Osquery, and Wazuh. Practical scenarios such as failed login detection, brute-force attack identification, dashboard creation, alert rule design, and incident documentation were performed to mirror real-world SOC activities. Additionally, security events were mapped to the MITRE ATT&CK framework to understand attacker tactics and techniques from a defensive perspective.

Overall, this assignment is relevant to cybersecurity operations as it bridges theoretical SOC concepts with practical execution, demonstrating how security monitoring and incident response workflows operate in real environments. It provides hands-on exposure to the tools, processes, and analytical thinking required for entry-level SOC and security operations roles.

---

2. Objective of the Assignment

The primary objective of this assignment is to develop a clear understanding of Security Operations Center (SOC) fundamentals and gain basic hands-on exposure to real-world security monitoring and incident response activities. The assignment aims to bridge the gap between theoretical security concepts and their practical application in a SOC environment.

From a theoretical perspective, the goal is to understand the purpose and functions of a SOC, including continuous monitoring, threat detection, alert triage, investigation, and response. This includes learning key security concepts such as log management, security monitoring objectives, incident response workflows, and the role of frameworks like NIST and MITRE ATT&CK in guiding SOC operations.

From a practical perspective, the assignment focuses on applying these concepts using a controlled lab environment. The objectives include:

- Setting up and using a SIEM platform to collect and analyze logs.
- Identifying suspicious activities such as failed login attempts and brute-force behavior.
- Visualizing security data through dashboards for better situational awareness.
- Designing and validating alert logic for security incidents.
- Practicing incident documentation using structured templates.
- Understanding how detected events map to MITRE ATT&CK tactics and techniques.

Overall, the assignment aims to build foundational SOC analyst skills by combining structured learning with hands-on exercises, enabling a practical understanding of how security events are monitored, analyzed, documented, and escalated in real-world cybersecurity operations.

---

3. Scope of the Assignment

The scope of this assignment is focused on developing a foundational understanding of Security Operations Center (SOC) concepts and workflows, supported by basic hands-on exercises using a simulated lab environment. The assignment covers core SOC responsibilities such as

log collection and analysis, security monitoring, alerting, incident response workflows, and security event documentation.

The areas covered within the scope include:

- Understanding the role and purpose of a SOC in proactive threat detection and continuous monitoring.
- Basic log management practices, including log collection, normalization, querying, and analysis.
- Use of common security tools such as SIEM platforms, network analysis tools, IDS/IPS, vulnerability scanners, and endpoint visibility tools.
- Identification and analysis of common security incidents, such as failed login attempts and brute-force activity.
- Creation of monitoring dashboards and conceptual alert rules to support SOC operations.
- Documentation of security events and incidents using structured formats.
- Mapping detected security events to the MITRE ATT&CK framework for better understanding of adversary behavior.

This assignment does not aim to implement a full-scale enterprise SOC or advanced production-grade security infrastructure. Advanced configurations, large-scale deployments, and complex automation were intentionally kept out of scope. Instead, the focus remains on building core SOC analyst skills, understanding workflows, and gaining practical familiarity with commonly used security tools and frameworks in a controlled learning environment.

---

4. Assignment Overview

This assignment is structured into two main components: Theoretical Knowledge and Practical Application. This approach ensures a balanced understanding of both SOC concepts and their real-world implementation.

The Theoretical Knowledge section focuses on core concepts related to Security Operations Centers, including SOC fundamentals, security monitoring basics, log management, security tools, incident response, and documentation standards. This section establishes the conceptual foundation required to understand how SOCs operate, the roles involved, and the frameworks and best practices that guide security operations.

The Practical Application section builds upon the theoretical foundation by applying these concepts in a controlled lab environment. It includes hands-on activities such as log analysis, security event identification, dashboard creation, alert rule design, vulnerability scanning, endpoint monitoring, and incident documentation. Practical scenarios were used to simulate common security incidents, allowing for experiential learning and reinforcing SOC workflows such as detection, analysis, and response.

Together, these two sections provide a structured progression from understanding what a SOC does to how SOC activities are performed in practice, ensuring that the assignment demonstrates both theoretical knowledge and practical competency at a foundational level.

Part A: Theoretical Knowledge

---

5. SOC Fundamentals and Operations

A Security Operations Center (SOC) is a centralized function responsible for monitoring, detecting, analyzing, and responding to cybersecurity threats. The primary goal of a SOC is to provide continuous visibility into security events and enable timely response to incidents to reduce organizational risk.

Purpose of a SOC

- The core purpose of a SOC includes:
- Continuous monitoring of systems, networks, and applications
- Early detection of security threats and suspicious activity
- Incident response and coordination
- Maintaining overall security posture through centralized oversight

SOC Roles and Responsibilities

SOC operations are typically structured across multiple roles to ensure efficient handling of security events:

- **Tier 1 SOC Analyst:**
  Monitors alerts generated by security tools, performs initial triage, and identifies false positives.
- **Tier 2 SOC Analyst:**
  Conducts deeper investigation of confirmed alerts, correlates logs from multiple sources, and determines the nature of the incident.
- **Tier 3 SOC Analyst / Threat Hunter:**
  Handles advanced investigations, performs threat hunting, and analyzes complex attack scenarios.
- **SOC Manager:**
  Oversees SOC operations, manages escalation, and coordinates incident response activities.

Core SOC Functions

Key functions performed within a SOC include:

- Log analysis to identify suspicious patterns and anomalies
- Alert triage and prioritization based on severity and impact
- Incident investigation and response
- Threat intelligence integration to enrich alerts with attacker context

Frameworks and Industry References

SOC operations are guided by established security frameworks and best practices:

- **NIST (National Institute of Standards and Technology)**
  NIST provides widely adopted guidelines for security monitoring and incident response, particularly through frameworks such as the NIST Cybersecurity Framework (CSF) and NIST SP 800-61 (Incident Response Guide). These frameworks define best practices for identifying security events, analyzing incidents, responding effectively, and improving processes through lessons learned. SOC teams rely on NIST guidance to design repeatable and well-governed security operations.
- **MITRE ATT&CK Framework**
  MITRE ATT&CK is a knowledge base that categorizes adversary behavior into tactics and techniques based on real-world attack patterns. It helps SOC analysts understand how attackers operate and why specific activities occur. In this assignment, detected

security events such as repeated failed login attempts were mapped to T1110 – Brute Force, aligning observed behavior with known attacker techniques. This mapping improves investigation accuracy, prioritization, and communication within SOC operations.

These frameworks support consistent and effective SOC workflows.

---

6. Security Monitoring and Log Management

Security monitoring is a core SOC activity focused on detecting anomalies, unauthorized access, and policy violations by continuously observing system and network activity. Effective monitoring allows SOC teams to identify potential threats early and initiate timely investigation and response.

Objectives of Security Monitoring

The primary objectives of security monitoring include:

- Detecting abnormal or suspicious behavior
- Identifying unauthorized access attempts
- Monitoring for violations of security policies
- Reducing the time required to detect security incidents

In this assignment, these objectives were demonstrated by identifying repeated failed authentication attempts and analyzing suspicious network activity.

Security Monitoring Tools

Common tools used for security monitoring include:

- **SIEM platforms** (e.g., Elastic SIEM) for centralized visibility and event correlation
- **Network traffic analyzers** (e.g., Wireshark) for inspecting packet-level activity

Practical usage in this assignment:

- **Elastic SIEM** was used to monitor and analyze system and authentication logs
- **Wireshark was** used to analyze a pre-recorded brute-force attack capture (bruteforce.pcap) to identify suspicious traffic patterns

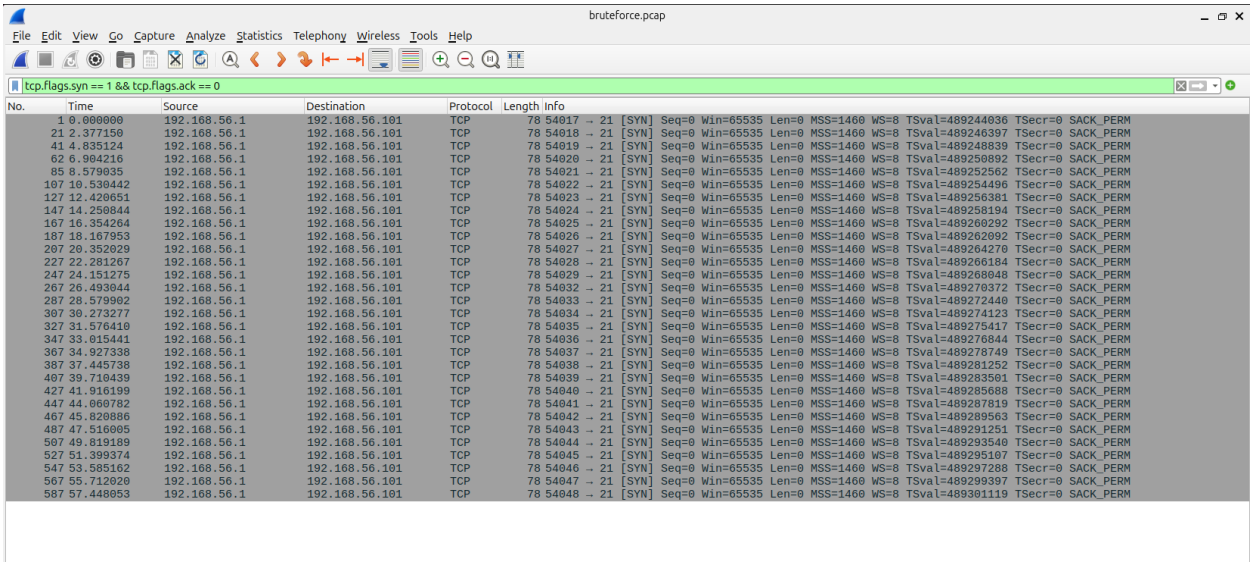

Figure 1: .pcap file in Wireshark

Key Monitoring Metrics

Security monitoring effectiveness is measured using metrics such as:

- **False Positives:** Legitimate activity incorrectly flagged as malicious
- **False Negatives:** Malicious activity that is not detected
- **Mean Time to Detect (MTTD):** Time taken to identify a security incident

Although precise metrics were not calculated, the exercises highlighted how accurate monitoring and analysis are essential for reducing false positives and improving detection efficiency.

Importance of Security Monitoring

Security monitoring enables SOC teams to:

- Gain continuous visibility into system and network activity
- Detect potential attacks such as brute-force attempts
- Support incident investigation and response workflows

This section establishes the foundational role of security monitoring in SOC operations, which is further reinforced through the practical log analysis and alerting activities performed later in the assignment.

---

7. Log Management Fundamentals

Log management is a foundational SOC capability that ensures security-relevant data is collected, structured, stored, and analyzed effectively to support monitoring and incident response activities.

Log Lifecycle

The log lifecycle consists of the following stages:

- **Collection**: Logs generated by systems, applications, and services
- **Normalization**: Converting logs into a structured and consistent format
- **Storage**: Centralized storage of logs for analysis
- **Analysis**: Querying and reviewing logs to identify security events
- **Retention**: Maintaining logs for investigation and compliance purposes

This lifecycle was observed throughout the lab setup, from log generation on the system to analysis in the SIEM platform.

Common Log Types

SOC teams typically work with multiple types of logs, including:

- **Syslog**: Operating system and service-level events
- **Authentication logs**: Login success and failure events
- **HTTP server logs**: Web access and response information
- **Windows Event Logs**: Security and system events

In this assignment, Syslog, authentication logs, and HTTP access logs were actively used for practical exercises.

Log Collection Pipeline

To understand log collection:

- Syslog was configured to forward logs to Elastic SIEM
- Test logs were generated on the Ubuntu system using the logger command
- The generated logs were successfully ingested and verified in Elastic SIEM

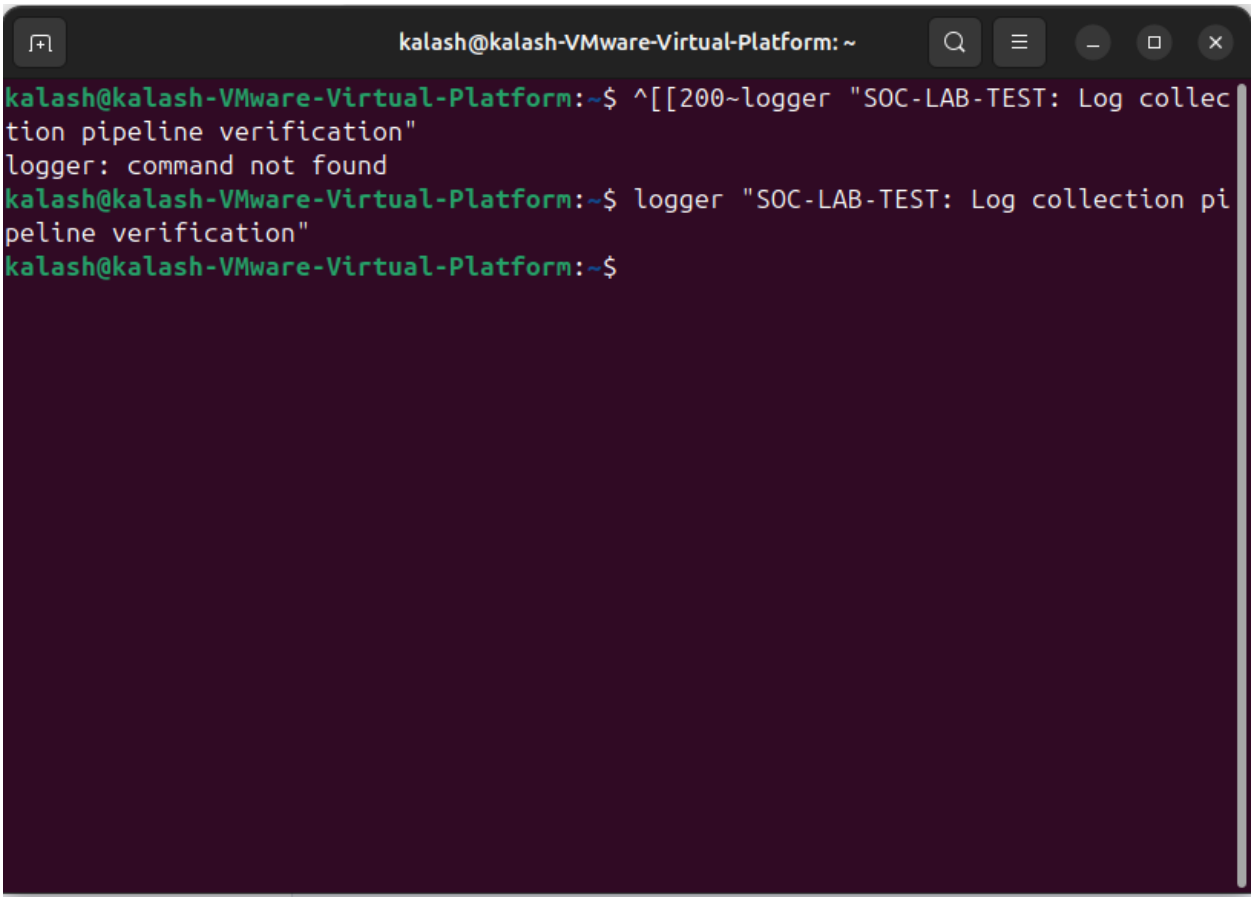

Figure 2: log generated

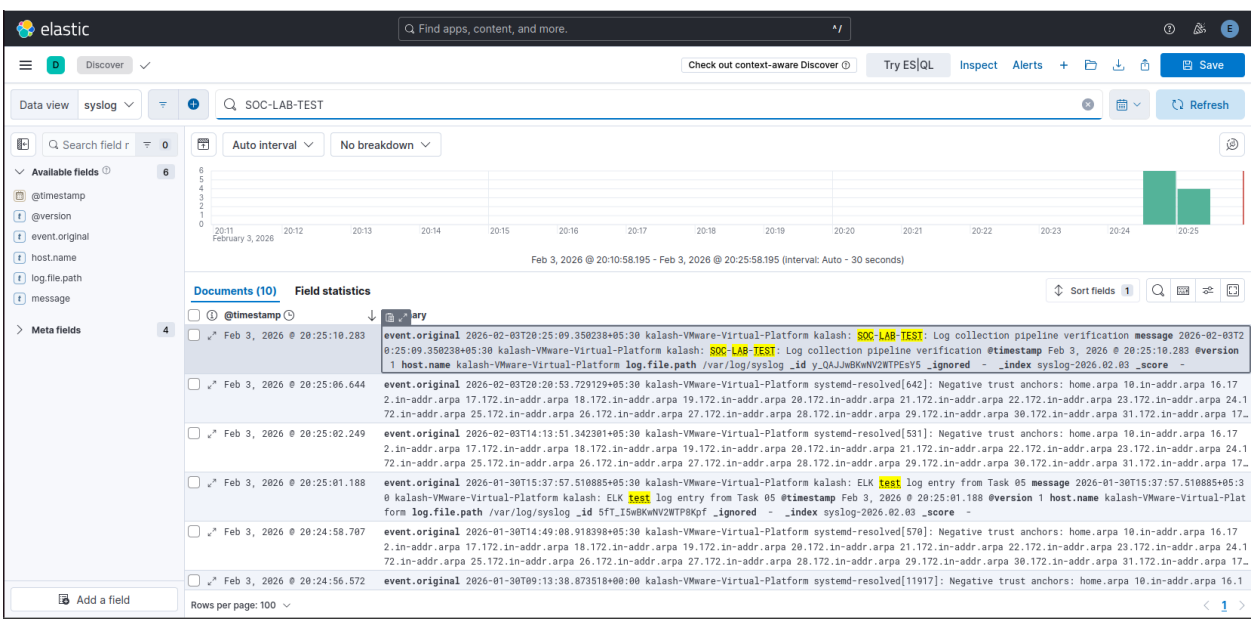

Figure 3: log parsed to SIEM

Log Normalization

Log normalization allows raw logs to be parsed into structured fields for easier analysis.

Practical exercise performed:

- A sample Apache access log was processed using Logstash
- Grok patterns were used to parse raw log entries
- Logs were converted into JSON format
- Key fields such as source IP, HTTP method, URI, and status code were validated

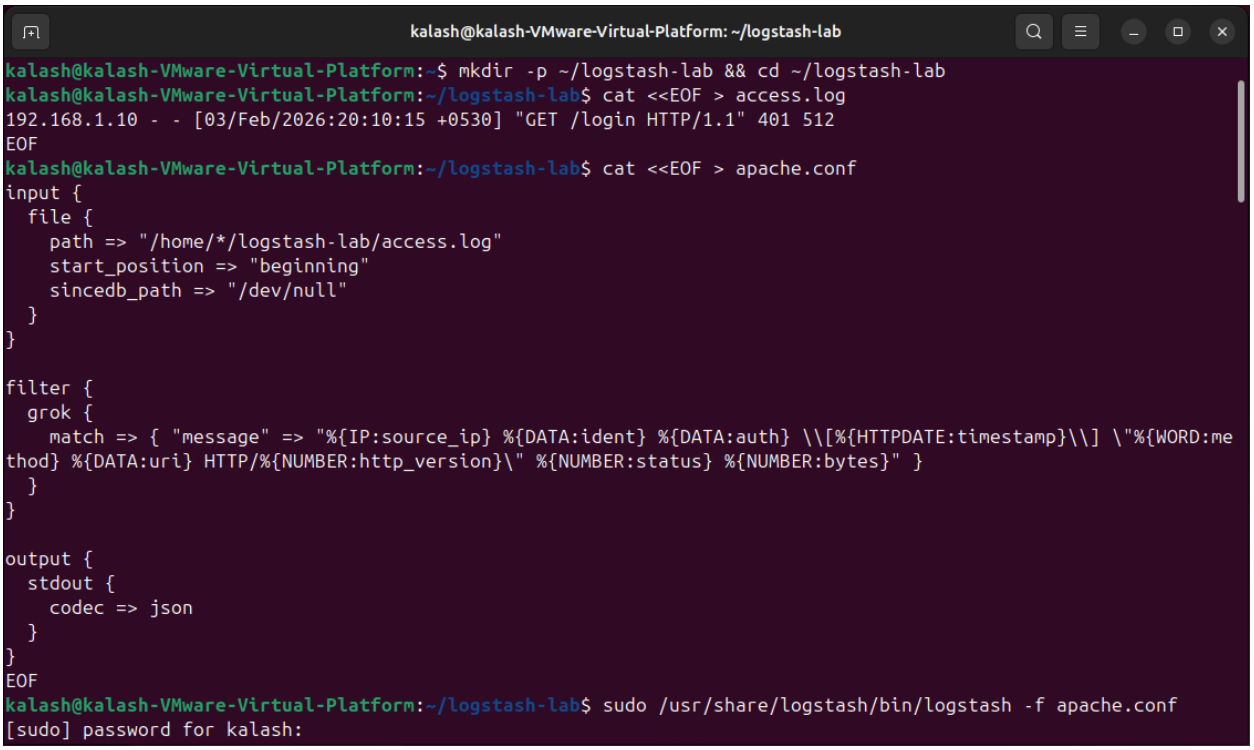

Figure 4: log normalization

Log Querying and Analysis

Logs stored in a SIEM can be queried to identify security-relevant events.

- Querying concepts similar to SQL/KQL were explored
- Filters and search queries in Elastic SIEM were used to analyze authentication-related activity
- Focus was placed on identifying repeated failed login patterns

This demonstrated how SOC analysts transform raw log data into actionable security insights.

Importance of Log Management

Effective log management:

- Enables accurate detection of security incidents
- Supports investigation and incident response
- Provides reliable evidence for security reporting

Through hands-on log generation, collection, normalization, and analysis, this assignment demonstrated the critical role of log management in SOC operations.

---

8. Security Tools and Technologies

Security operations rely on multiple tools working together to provide visibility, detection, and response capabilities. In this assignment, common SOC tools were studied conceptually and selectively implemented in a lab environment to gain practical exposure.

Key Security Tools

- **SIEM:** Used for centralized log collection and analysis (e.g., Elastic SIEM)
- **EDR/XDR**: Provides endpoint visibility and behavioral detection (e.g., CrowdStrike, Wazuh)
- **IDS/IPS:** Monitors network traffic for malicious activity (e.g., Snort)
- **Vulnerability Scanners:** Identify system and service vulnerabilities (e.g., Nessus)

Snort (IDS/IPS)

- Snort was installed on the Ubuntu system to understand IDS/IPS concepts.
- A custom rule was written to detect HTTP requests containing a malicious domain string.
- Traffic was generated to trigger the rule, and troubleshooting was performed.

Outcome:

- While the rule configuration and testing process were completed, reliable alert generation could not be consistently validated.
- This exercise was used to understand rule structure, traffic inspection, and IDS limitations rather than production-level enforcement.

Nessus – Vulnerability Scanning

Nessus Essentials was used to perform a vulnerability scan against a target virtual machine.

Practical steps performed:

- Nessus Essentials was installed and configured.
- A Basic Network Scan was launched against the target host.
- The scan completed successfully and identified vulnerabilities across multiple severity levels.

Observed results:

- Critical, High, Medium, Low, and Informational vulnerabilities were identified.
- Authentication was not configured, resulting in unauthenticated scan results.
- The scan provided remediation guidance for detected issues.

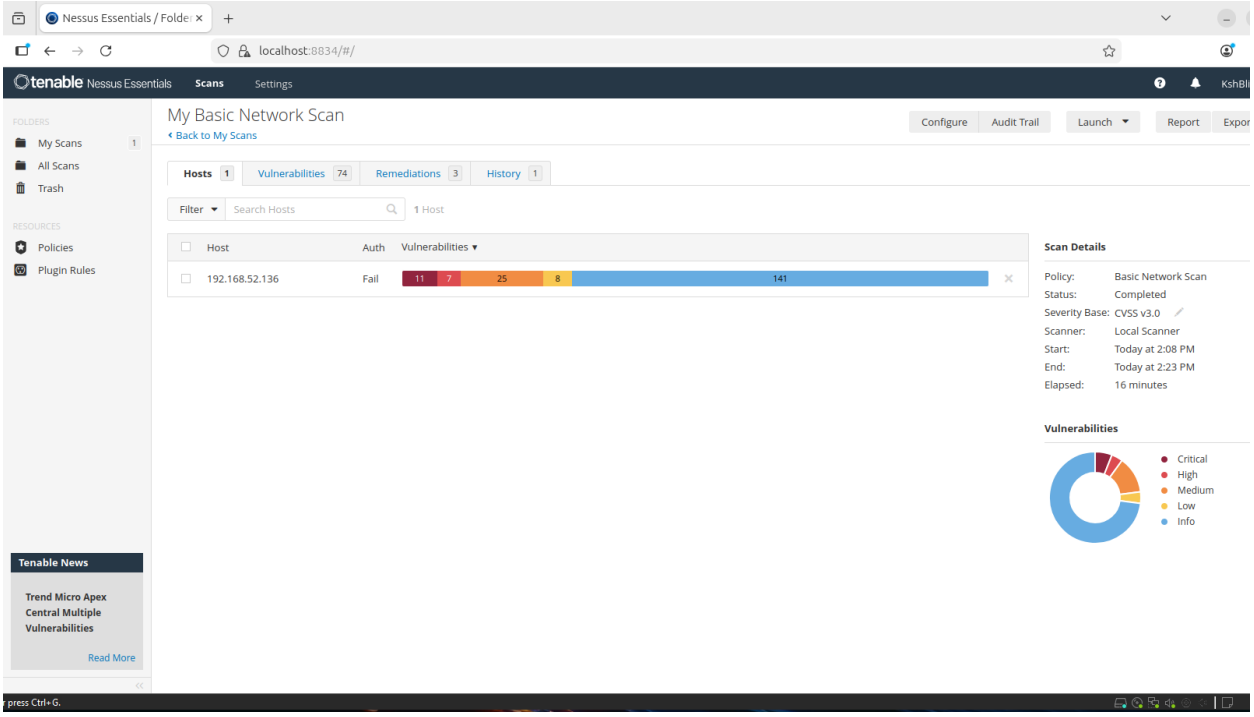

Figure 5: Nessus Vulnerability Scan on Metaspliotable

This exercise demonstrated how vulnerability scanners are used to:

- Identify exposed services and misconfigurations
- Prioritize risks using CVSS scoring
- Support remediation planning in SOC workflows

Osquery – Endpoint Visibility

Osquery was installed to gain visibility into endpoint-level activity.

Practical usage:

- Osquery interactive shell was used to query system information.
- Queries such as SELECT * FROM processes; were executed to list running processes.
- This demonstrated how SOC analysts can inspect endpoint state and detect suspicious processes.

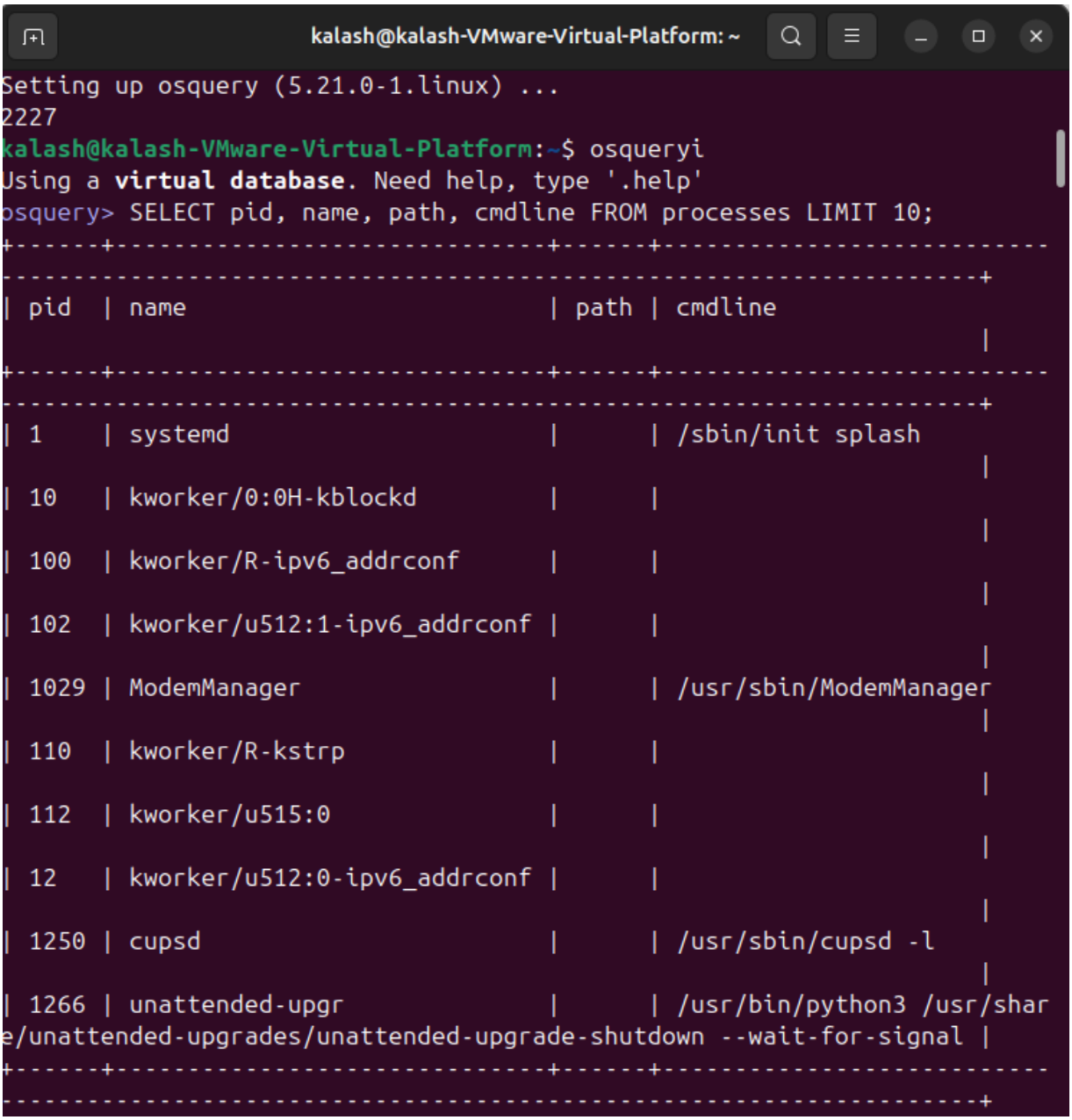

Figure 6: OSquery1

```
+------+-----------------------------+------+-------------------------------------
-----------------------------------------------------------+
osquery> SELECT user, host, time FROM logged_in_users;
+----------+-------------------+------------+
| user     | host              | time       |
+----------+-------------------+------------+
| reboot   | 6.14.0-37-generic | 1770192272 |
| kalash   | login screen      | 1770192301 |
| kalash   | tty2              | 1770192301 |
|          |                   | 1770194780 |
| runlevel | 6.14.0-37-generic | 1770192488 |
+----------+-------------------+------------+
```

Figure 7: OSquery2

Summary

This section provided exposure to commonly used SOC tools by:

- Practicing vulnerability assessment using Nessus
- Understanding IDS rule creation and limitations using Snort
- Querying endpoint data using Osquery

The focus was on foundational understanding and hands-on familiarity, not enterprise-scale deployment.

---

9. Core Security Concepts

Understanding basic security concepts is essential for interpreting security events and making informed decisions within a SOC. These concepts form the foundation for security monitoring, risk assessment, and incident response.

CIA Triad

The CIA triad represents the three core principles of information security:

- **Confidentiality:**
  Ensuring that information is accessible only to authorized users.
  Example: Preventing unauthorized access to sensitive data.
- **Integrity:**
  Ensuring that data remains accurate and unaltered.
  Example: Detecting unauthorized changes to system or log files.

- **Availability:**

  Ensuring that systems and services remain accessible when needed.

  Example: Protecting systems from denial-of-service attacks.

These principles guide how security controls are designed and evaluated.

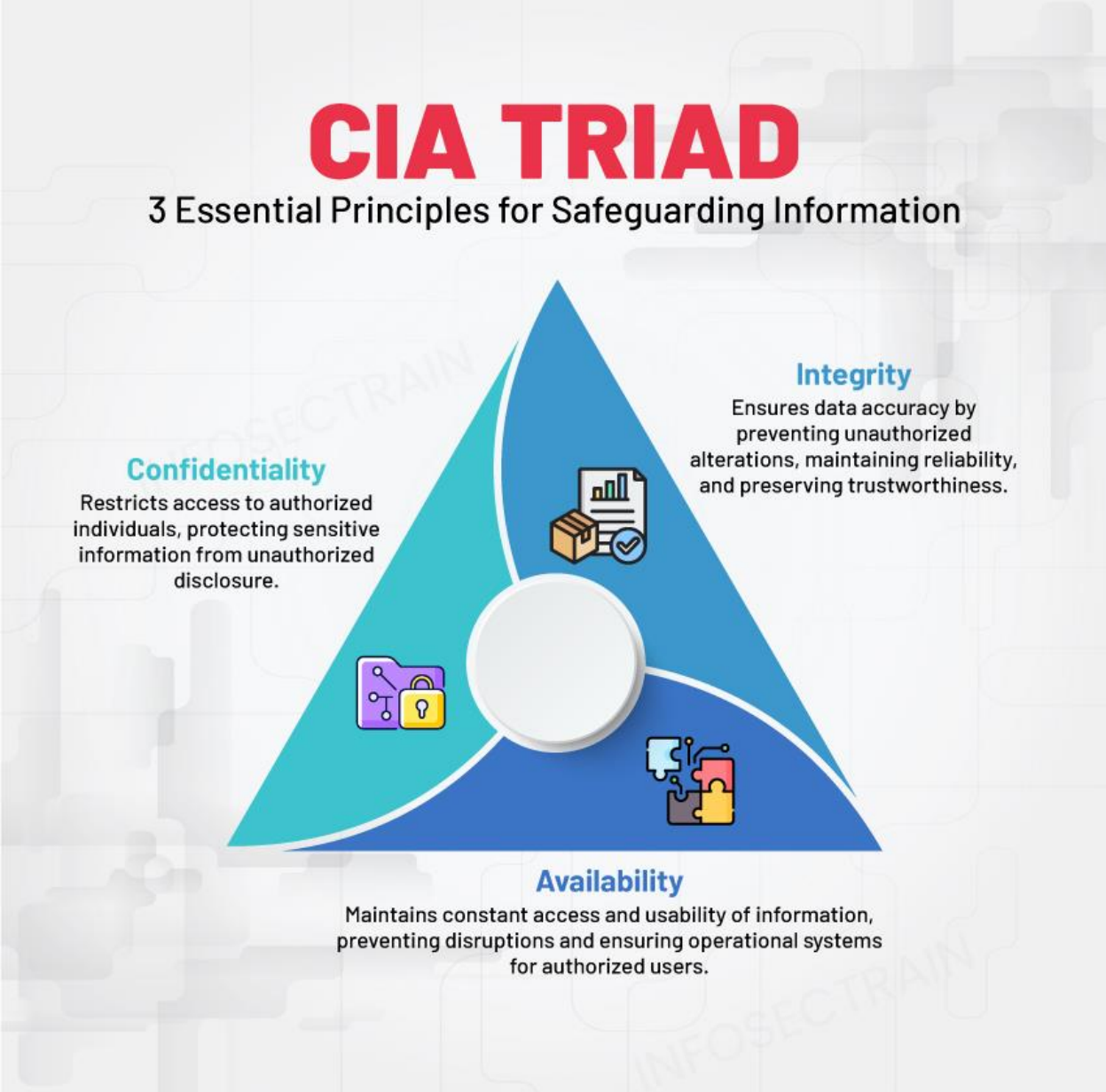

Figure 8: CIA Triad

Threat, Vulnerability, and Risk

- **Threat**: A potential cause of an unwanted incident (e.g., attacker attempting brute-force login).
- **Vulnerability**: A weakness that can be exploited (e.g., weak authentication controls).

- **Risk**: The likelihood and impact of a threat exploiting a vulnerability.

SOC analysts assess these factors when prioritizing alerts and incidents.

Defense-in-Depth

Defense-in-depth is a layered security approach where multiple controls are implemented to reduce reliance on a single protection mechanism.

Examples include:

- Firewalls and network controls
- Authentication and access controls
- Monitoring and alerting through SIEM
- Endpoint monitoring tools

This approach increases resilience against attacks.

Zero Trust

Zero Trust follows the principle of “never trust, always verify.”

Key ideas include:

- No implicit trust for users or devices
- Continuous authentication and authorization
- Monitoring all access attempts

Zero Trust concepts influence modern SOC monitoring and access control strategies.

Learning References

- Security terminology was reinforced through structured learning methods.
- Industry case studies, such as the Equifax breach, highlight the real-world impact of unpatched vulnerabilities and weak security controls.

---

10. Security Operations

A security operations workflow defines how a SOC detects, investigates, responds to, and closes security incidents in a structured and repeatable manner. This assignment focuses on understanding and simulating a phishing email incident workflow, which represents a common real-world SOC scenario.

Workflow Stages

1. **Detection**
    - A phishing email alert is generated by an email security gateway or SIEM.
    - The alert indicates a potentially malicious email delivered to a user.
2. **Triage**
    - The SOC analyst reviews the alert details and severity.
    - The analyst verifies whether the targeted user interacted with the email (clicked a link or opened an attachment).
    - Based on this assessment, the incident priority is determined.
3. **Investigation**
    - The investigation phase focuses on validating and understanding the threat:
    - Analyze email headers to identify sender anomalies
    - Extract URLs or attachments from the email
    - Check indicators of compromise (IOCs) against threat intelligence sources
    - Review user authentication and login activity for suspicious behavior
4. **Containment**
    - If malicious activity is confirmed:
    - Block the sender domain or email address
    - Quarantine the phishing email across all mailboxes
    - Disable the affected user account if compromise is suspected
5. **Eradication**
    - Actions taken to remove the threat completely:
    - Remove all malicious email artifacts
    - Reset compromised user credentials
    - Block malicious URLs or IP addresses
6. **Recovery**
    - Restore user access after remediation
    - Monitor the affected account and systems for recurrence
    - Ensure systems are operating normally

7. **Post-Incident Review**

- Update detection and filtering rules
- Conduct user awareness or phishing training if required
- Document findings and lessons learned for future improvement

Practical Implementation

A phishing incident response flowchart was created to visually represent the complete SOC workflow, from alert detection to incident closure.

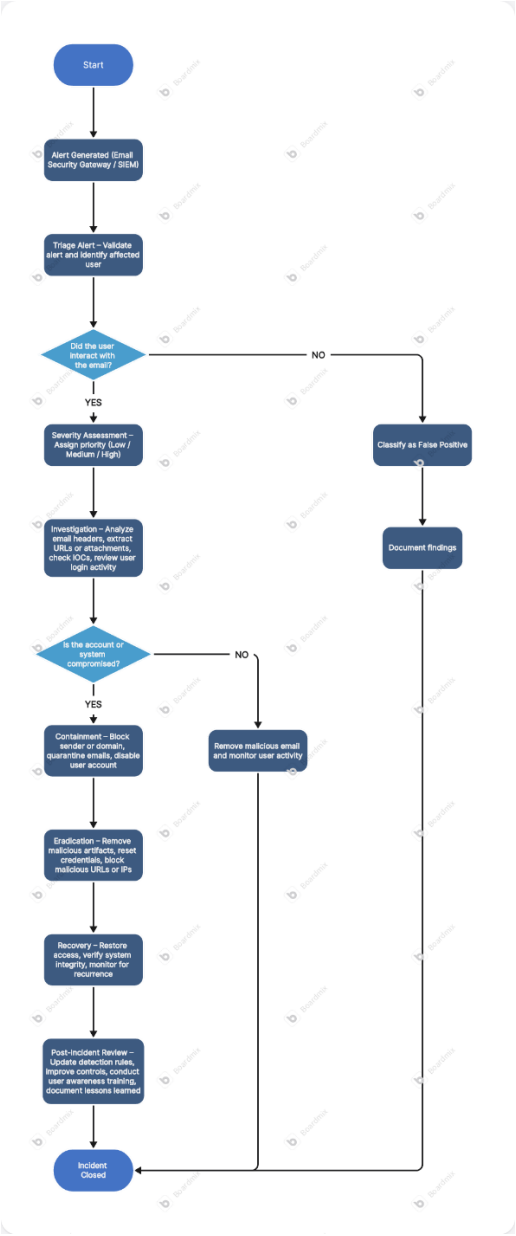

Figure 9: Phishing Flowchart

This flowchart provides a clear visual representation of decision points, response actions, and escalation paths commonly followed by SOC teams.

Summary

- This workflow demonstrates how SOC teams handle phishing incidents using a structured approach that ensures:
- Timely detection
- Accurate investigation
- Effective containment and remediation
- Continuous improvement through post-incident review

---

11. Incident Response Basics

Incident Response (IR) is a structured approach used by security teams to identify, contain, eradicate, and recover from security incidents, while minimizing impact and preventing recurrence. A clearly defined IR lifecycle ensures incidents are handled consistently and effectively.

Incident Response Lifecycle

The incident response process follows the standard lifecycle defined in NIST SP 800-61:

1. **Preparation**

Preparation focuses on ensuring the organization is ready to respond before an incident occurs.
In this assignment, preparation included:

- Email security controls enabled to detect phishing attempts
- Multi-Factor Authentication (MFA) policies defined
- SIEM configured to monitor authentication and login activity

2. **Identification**

Identification involves detecting and confirming a security incident.
Indicators in this scenario included:

- Alert triggered for suspicious login activity

- User reporting a phishing email

These signals confirmed a potential credential phishing attack.

3. **Containment**

Containment aims to limit the spread and impact of the incident.

Actions taken:

- Disabling the compromised user account
- Blocking the phishing sender and domain
- Preventing further access using compromised credentials

4. **Eradication**

Eradication removes the root cause of the incident.

Steps performed:

- Removing phishing emails from mailboxes
- Resetting affected user credentials
- Revoking active user sessions

5. **Recovery**

Recovery focuses on safely restoring normal operations.

Recovery actions included:

- Restoring user access after remediation
- Enforcing MFA on the user account
- Monitoring login activity for suspicious behavior

6. **Lessons Learned**

The final phase focuses on improving security posture based on the incident.

Key improvements identified:

- Enhancing phishing detection and alerting rules
- Updating user awareness and training programs
- Strengthening authentication and access control policies

Framework Reference

The NIST SP 800-61 Incident Handling Guide provides the foundation for this lifecycle, emphasizing:

- Clear incident classification

- Structured response stages
- Continuous improvement through post-incident review

Summary

This section demonstrates how the incident response lifecycle can be applied to a credential phishing attack, aligning theoretical IR concepts with a realistic SOC response scenario. The exercise highlights the importance of preparation, rapid containment, and continuous improvement in effective incident handling.

---

12. Documentation Standards in Security Operations

Documentation is a critical component of Security Operations Center (SOC) activities, as it ensures consistency, accountability, and traceability during and after security incidents. Proper documentation enables SOC teams to respond effectively, support audits, and improve future detection and response capabilities.

Types of SOC Documentation

In this assignment, the following common SOC documentation types were studied:

- **Incident Reports** – Formal records describing security incidents, response actions, and outcomes
- **Runbooks** – Step-by-step response procedures for specific incident types
- **Standard Operating Procedures (SOPs)** – Defined operational processes for SOC activities
- **Post-Incident Reviews** – Analysis of incidents to identify gaps and improvements

Applied Documentation Practice

As part of the practical work, incident documentation was created using industry-recognized standards:

- A mock Distributed Denial of Service (DDoS) incident report was prepared following the structure recommended in the SANS Incident Handler's Handbook

- A security event record was documented for a simulated brute-force authentication activity, capturing key details such as date/time, source IP, event description, and response actions

Purpose and Value

This exercise demonstrated how structured documentation:

- Supports effective incident tracking and escalation
- Preserves institutional knowledge for future incidents
- Enables continuous improvement through lessons learned

Appendix Reference

Detailed documentation templates and sample incident reports created as part of this assignment are provided in **Appendix A** for reference.

Part B: Practical Application

---

13. Log Analysis and Monitoring Practice

Log analysis is a core SOC activity used to identify suspicious behavior, validate alerts, and support incident investigation. This section focuses on analyzing authentication-related events to detect potential brute-force activity.

Windows Event Log Analysis

Objective:
Identify failed authentication attempts and detect brute-force behavior using Windows Security logs.

Practical steps performed:

- Failed login attempts were generated on a Windows virtual machine by entering incorrect credentials multiple times.
- Windows Event Viewer was used to analyze Security logs.
- Logs were filtered for:

- Event ID 4625 – Failed logon attempts

Observations:

- Multiple failed login events originating from the same source were identified.
- Repeated failures within a short time window indicated potential brute-force behavior.
- Filtered results were reviewed to understand patterns such as frequency and timestamps.

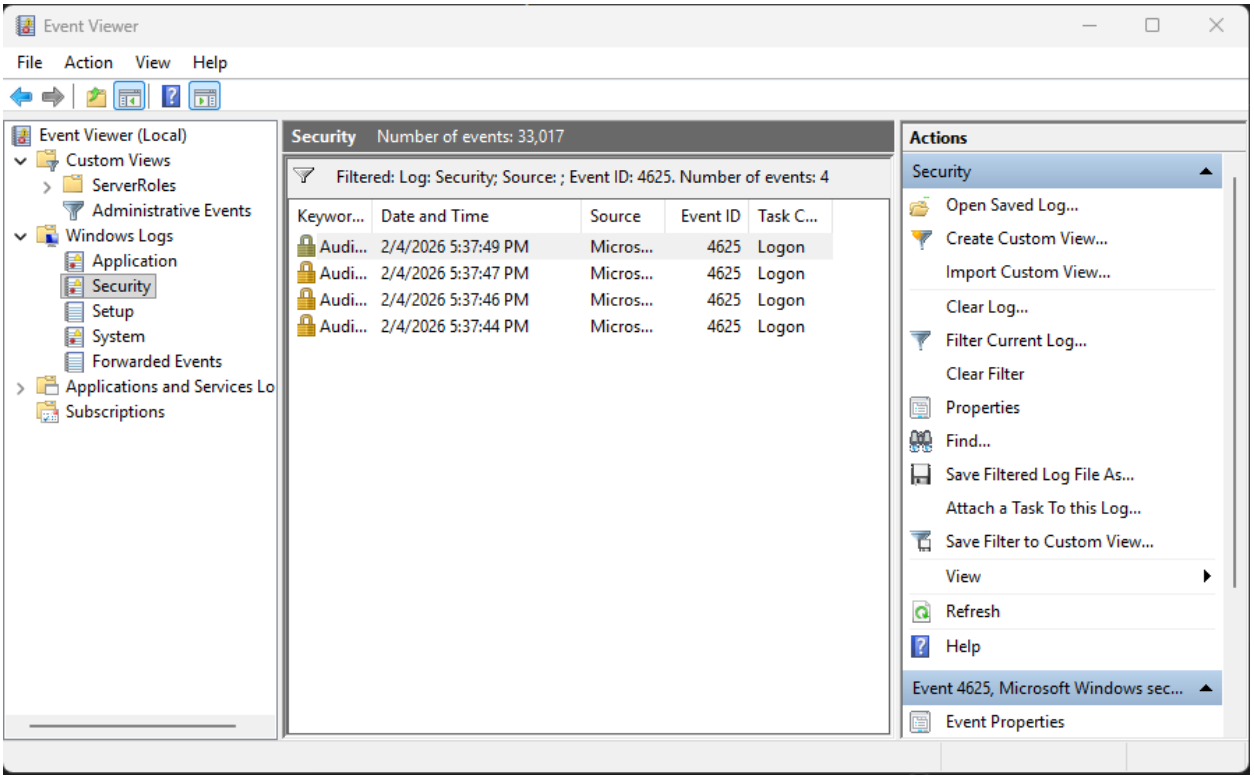

Figure 10: Windows Event Viewer showing filtered Event ID 4625 entries

SIEM-Based Log Analysis

To correlate host-level events with centralized monitoring:

- Authentication-related logs were forwarded to Elastic SIEM.
- Failed login events were visible and searchable within the SIEM interface.
- This demonstrated how endpoint logs can be centrally analyzed for SOC monitoring and investigation.

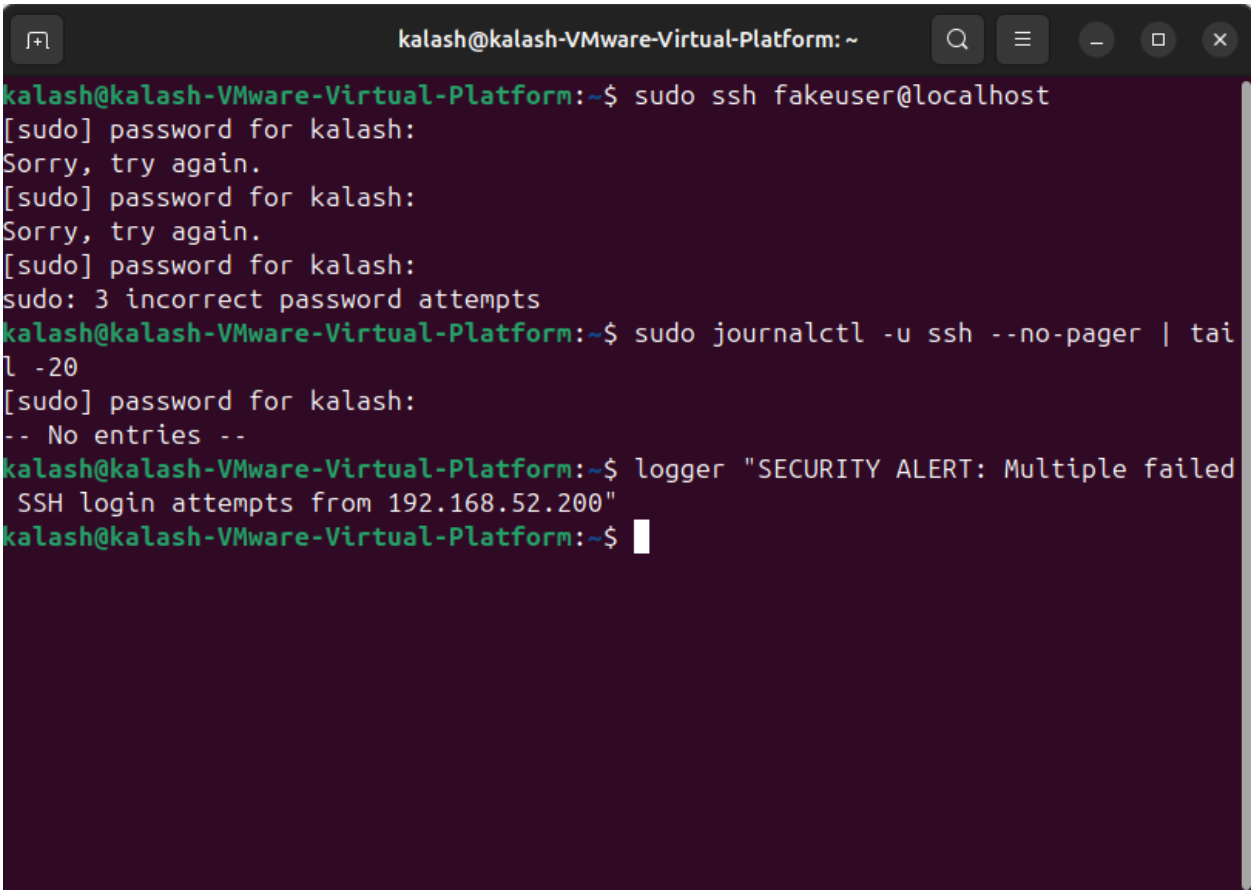

Figure 11: Intentional login failure

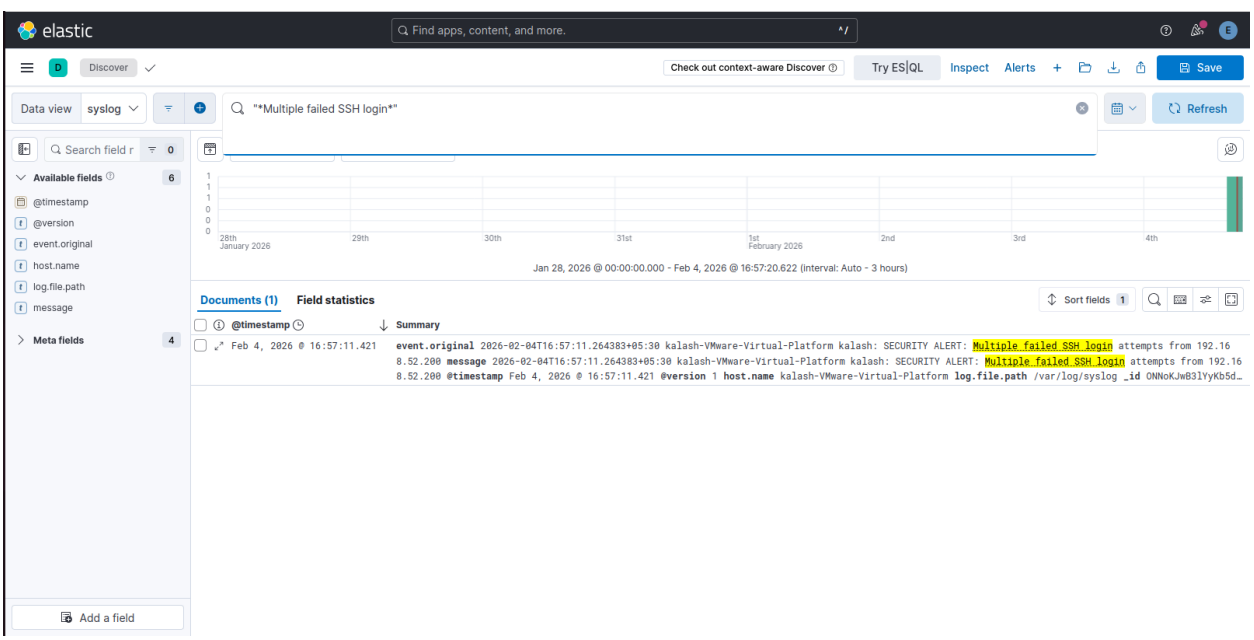

Figure 12: Failed login logs generated

Advanced Task: Brute-Force Detection

Objective:

Demonstrate detection of brute-force login behavior through log analysis.

Performed activity:

- Multiple failed login attempts were generated intentionally.
- Logs were analyzed in both Windows Event Viewer and Elastic SIEM.
- The observed activity matched common brute-force authentication patterns, such as repeated failures targeting user accounts within a short time window.

This exercise reinforced how SOC analysts detect authentication abuse using log correlation and behavioral patterns, rather than single events.

Browser History Analysis

Browser history analysis is commonly used during SOC investigations to identify access to suspicious or malicious URLs. Tools such as Eric Zimmerman's utilities (LECmd) can be used to parse browser artifacts and review user browsing activity.

This type of analysis is especially relevant in phishing, malware delivery, and user-driven compromise investigations and complements log-based detection techniques.

Summary

This section demonstrated practical log analysis by:

- Detecting failed authentication attempts using Windows Event Logs
- Correlating authentication events using a SIEM platform
- Identifying brute-force behavior through repeated failed login patterns
- Understanding how user activity artifacts support SOC investigations

The exercise highlights the importance of log analysis in early threat detection and effective SOC investigations.

---

14. Security Event Documentation

Security event documentation is a key SOC activity used to record, track, and assess individual security-related events that may or may not escalate into full incidents. Proper documentation ensures events are traceable, auditable, and can be reviewed for trends or escalation decisions.

Security Event Documentation Approach

A standardized documentation format was used to record security events with the following fields:

- **Date / Time**
- **Source IP**
- **Event ID / Type**
- **Description**
- **Action Taken**

Using a consistent template helps SOC analysts communicate findings clearly and supports effective handover, investigation, and reporting.

Practical Security Event Documentation

As part of this assignment, a security event record was created to document a simulated brute-force authentication attempt identified through log analysis.

The documented event captured:

- The time and source of the activity
- The nature of the event (multiple failed login attempts)
- Analysis performed using centralized log monitoring
- The response action taken, including monitoring and escalation readiness

This exercise demonstrated how SOC teams document individual security events before determining whether escalation to a full incident response is required.

Importance of Security Event Documentation

Effective security event documentation:

- Creates a clear audit trail of suspicious activity
- Supports incident escalation and response decisions
- Preserves investigation context for future reference
- Enables trend analysis and continuous improvement

Appendix Reference

Sample security event records created as part of this assignment are provided in **Appendix B** for reference.

Summary

This section reinforces the importance of structured security event documentation as part of daily SOC operations, ensuring events are consistently recorded, reviewed, and acted upon when necessary.

---

15. Dashboards and Alerting Concepts

Monitoring dashboards are used in SOC environments to provide real-time visibility into security events, alert trends, and suspicious activity. Dashboards help analysts quickly identify anomalies and prioritize investigation efforts.

Dashboard Objectives

The primary objectives of the dashboards created were:

- Identify sources generating the highest number of security-related events
- Observe patterns and frequency of critical events
- Support quick situational awareness for SOC analysts

Kibana Dashboard Configuration

As part of this assignment, monitoring dashboards were created using Kibana to visualize security-related log data collected in Elastic SIEM.

Top Event Sources Visualization

- A bar chart visualization was created to display the Top 10 sources generating events
- The dashboard used the available log data view (syslog-based index)

- Event count was plotted against source identifiers to identify noisy or high-activity sources

Critical Event Frequency Visualization

- A second visualization was configured to show the frequency of security-relevant events over time
- This helped identify spikes in activity and potential abnormal behavior patterns

These visualizations demonstrated how centralized log data can be transformed into actionable insights for SOC monitoring.

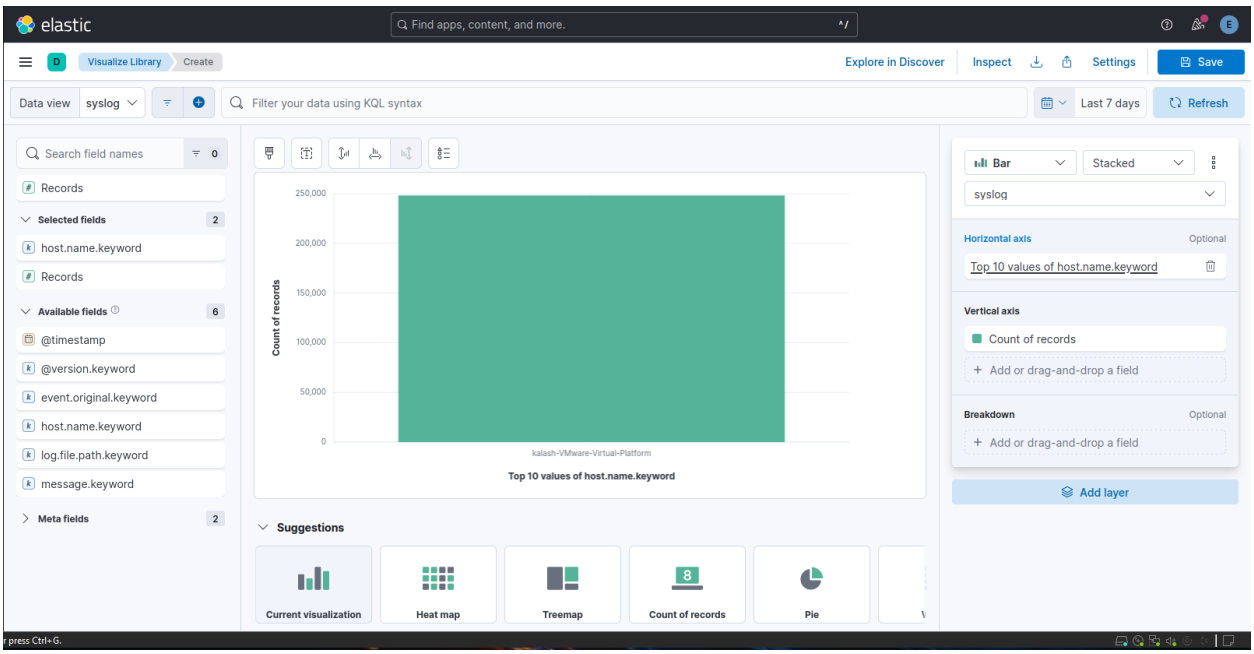

Figure 13: Top 10 event sources

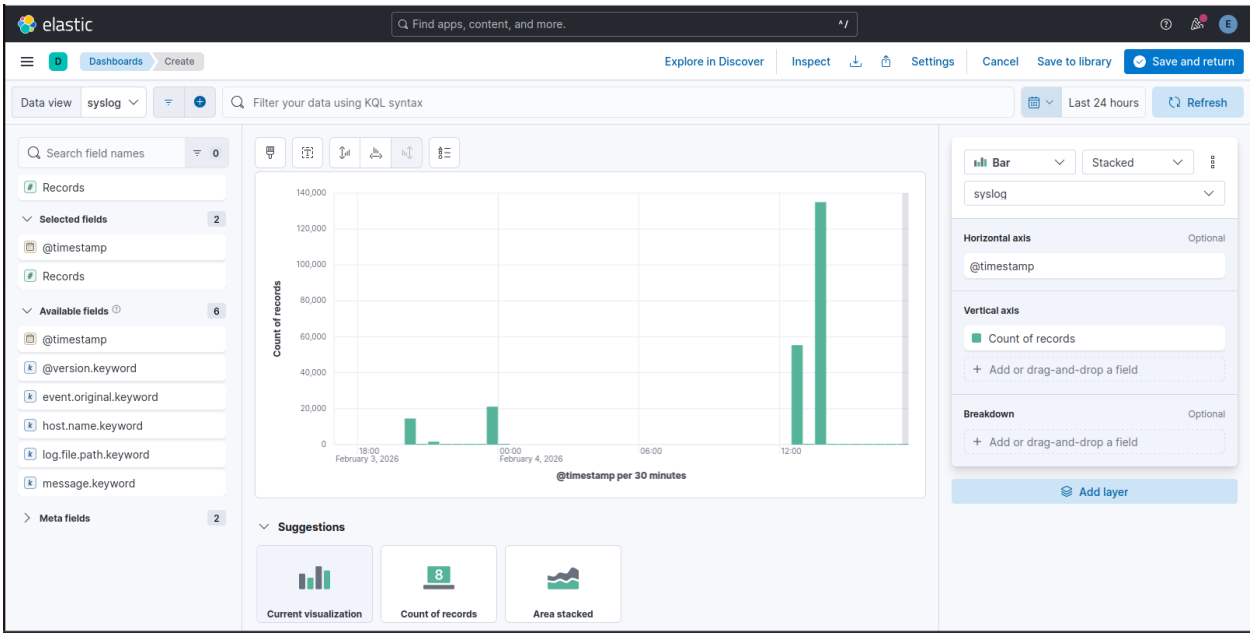

Figure 14: event frequency over time

Use of Pre-Built Dashboards

Pre-built dashboards, such as those based on Sigma detection rules, were reviewed conceptually to understand how standardized detection logic can be quickly deployed in SOC environments. These dashboards are commonly used to accelerate threat detection and maintain consistency across monitoring setups.

Summary

This section demonstrated the creation of custom monitoring dashboards in Kibana to support SOC visibility. The dashboards provided insight into event sources and activity trends, reinforcing the role of visualization in effective security monitoring.

---

16. Configuring Alert Rules

Alert rules are a core component of SOC operations, enabling automated detection of suspicious activity and reducing reliance on manual log review. This section focuses on designing an alert rule for detecting brute-force authentication attempts.

Objective

Detect potential brute-force attacks by identifying multiple failed login attempts occurring within a short time window.

Alert Rule Design (Conceptual & Practical Planning)

A threshold-based detection rule was designed to identify repeated authentication failures indicative of brute-force behavior.

Rule Logic

- **Data Source / Index:** syslog-*
- **Detection Condition:**
  Trigger an alert if 5 or more failed SSH login events are observed from the same source within 5 minutes
- **Detection Method:**
  Pattern-based matching on log messages indicating failed authentication attempts
- **Severity Level:** Medium

This rule design aligns with common SOC detection use cases for identifying early-stage credential abuse.

Testing Approach

To validate the detection logic:

- Failed SSH login attempts were simulated in the lab environment using incorrect credentials.
- These events were confirmed to be ingested and visible in Elastic SIEM.
- The expected behavior of the rule was verified conceptually by observing event frequency and timestamps.

Limitation Encountered

During implementation, detection rule creation was restricted due to insufficient permissions for the current Elastic SIEM user role.

This limitation prevented:

- Creating or enabling custom detection rules
- Configuring alert thresholds directly in the SIEM interface

Such restrictions are common in lab environments or non-administrative SIEM deployments, where detection engine permissions are limited.

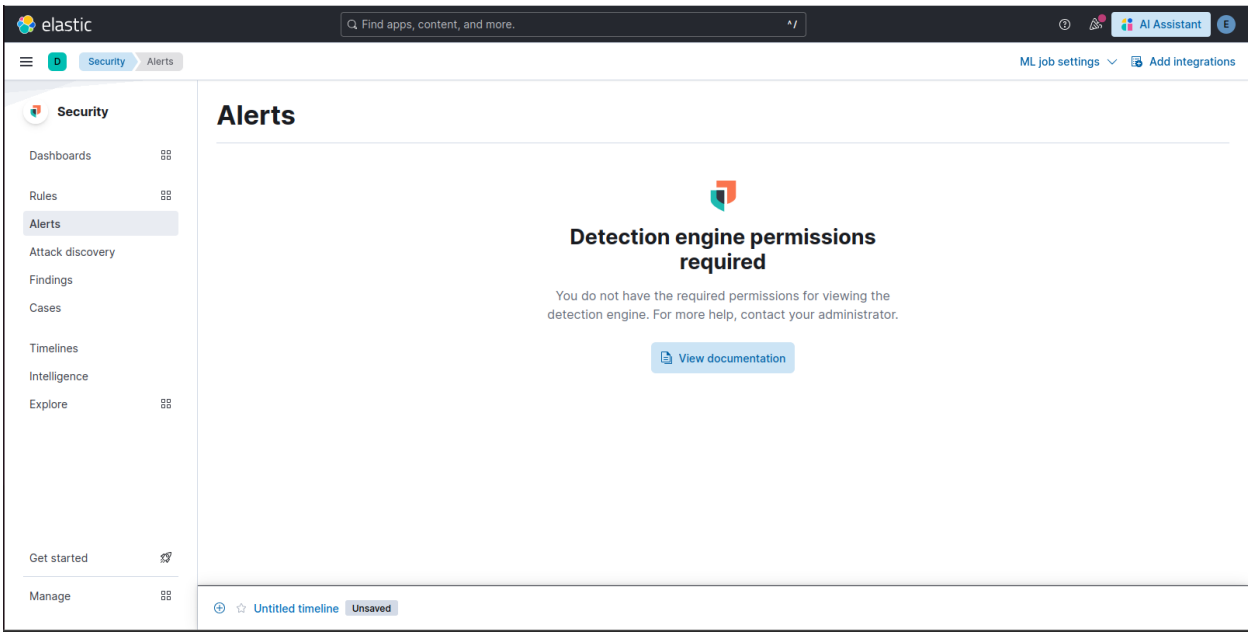

Figure 15: Wazuh limitation

Advanced Task – Wazuh Alerting

An advanced alerting use case was reviewed conceptually using Wazuh:

- Detect 3 or more failed login attempts within 2 minutes
- Correlate authentication failures at the agent level
- Generate alerts based on predefined rule thresholds

This approach demonstrates how endpoint-based SIEM/XDR platforms can complement centralized log monitoring.

Summary

Although full alert deployment was restricted by SIEM permissions, this section demonstrated:

- Proper design of a brute-force detection rule
- Understanding of threshold-based alerting logic
- Knowledge of validation and testing approaches
- Awareness of real-world SOC permission constraints

This reflects realistic SOC conditions where analysts may design and validate detections even when deployment rights are restricted.

---

17. Learning Approach

This assignment followed a hands-on learning approach that combined tool-based experimentation with framework-driven analysis, simulating how foundational SOC skills are developed in real environments.

Mini-SOC Lab Setup

A basic SOC lab environment was established using:

- **Wazuh** for centralized security monitoring and event visibility
- **Osquery** for endpoint-level visibility and system state inspection

The lab setup focused on understanding how:

- Security events are collected from endpoints
- Logs are centralized and reviewed
- Host activity can be queried and analyzed at the endpoint level

A local Wazuh deployment was configured, and an agent was added to enable endpoint monitoring and log ingestion.

Endpoint Visibility with Osquery

Osquery was used to demonstrate endpoint monitoring capabilities by querying system information such as:

- Running processes
- System-level activity
- Host metadata

This helped illustrate how endpoint telemetry complements SIEM-based monitoring by providing deeper visibility into host behavior.

MITRE ATT&CK Mapping

The MITRE ATT&CK framework was used as a reference model to understand how detected activities can be mapped to known adversary tactics and techniques.

For example:

- Repeated authentication failures can be mapped to Credential Access tactics
- Suspicious command execution or scripting activity aligns with techniques such as T1059 (Command and Scripting Interpreter)

This mapping approach helps SOC analysts:

- Standardize threat classification
- Improve detection coverage
- Align alerts with known adversary behaviors

Summary

This learning approach reinforced:

- How a basic SOC lab can be built using open-source tools
- The importance of combining SIEM visibility with endpoint telemetry
- The value of MITRE ATT&CK as a framework for understanding attacker behavior

Together, these elements support structured detection, investigation, and continuous improvement within SOC operations.

---

18. Observations and Key Learnings

This assignment provided a comprehensive introduction to Security Operations Center (SOC) fundamentals by combining theoretical understanding with practical exposure to commonly used security tools and workflows.

Key Observations

- Centralized log collection and monitoring are critical for effective threat detection and investigation.
- Individual security events often appear benign in isolation but reveal malicious patterns when analyzed over time.
- SIEM platforms play a vital role in correlating logs, visualizing activity, and supporting SOC decision-making.
- Practical lab environments may impose limitations (e.g., restricted permissions), which reflects real-world SOC operational constraints.
- Visualization through dashboards significantly improves situational awareness and prioritization.

Key Learnings

- Gained a foundational understanding of SOC roles, responsibilities, and core operational workflows.
- Learned how security monitoring helps detect anomalies such as brute-force authentication attempts.
- Developed hands-on experience with:
    - Log ingestion and analysis using Elastic SIEM
    - Network traffic analysis using Wireshark
    - Vulnerability assessment using Nessus
    - Endpoint visibility using Osquery
    - Security monitoring using Wazuh
- Understood the importance of structured documentation for security events and incidents.
- Applied industry frameworks such as NIST and MITRE ATT&CK to align technical findings with standardized security practices.

Overall Outcome

The assignment strengthened both conceptual knowledge and practical skills required for entry-level SOC operations. It highlighted how monitoring, analysis, alerting, and documentation work together to support effective cybersecurity defense.

19. Challenges and Limitations

During the execution of this assignment, several technical and operational challenges were encountered. These challenges provided valuable learning experiences and reflected realistic constraints commonly faced in lab-based SOC environments.

Tool and Permission Limitations

- Detection rule creation in Elastic SIEM was restricted due to insufficient user permissions.
- This limitation prevented full deployment and testing of custom alert rules, despite logs being successfully ingested and analyzed.
- Such constraints are typical in non-administrative or training environments and highlighted the separation of analyst and administrator roles in SOC operations.

Integration and Environment Constraints

- Running multiple security tools (Elastic Stack, Nessus, Wazuh, Osquery) on a single virtual machine led to resource and disk space limitations, requiring careful management.
- Certain tools required specific operating system versions or exclusive ports, limiting simultaneous full-scale deployments.
- Network-based testing (e.g., Snort rule validation) required additional tuning and environment isolation, which was constrained by available lab time.

Partial Implementation of Advanced Tasks

- Some advanced configurations, such as custom IDS rule validation and automated alert triggering across platforms, were designed conceptually but not fully operationalized.
- Browser artifact analysis using third-party forensic tools was reviewed at a conceptual level to maintain focus on core SOC monitoring objectives.

Operational Realism

- Lab-based simulations do not fully replicate enterprise SOC environments, particularly in areas such as:
    - Multi-user role separation
    - Production-scale alert volumes
    - Automated response orchestration

Despite these limitations, the assignment successfully met its learning objectives by focusing on foundational SOC skills.

Summary

The challenges encountered reinforced the importance of:

- Proper planning and resource allocation
- Understanding role-based access controls
- Adapting workflows based on environmental constraints

These experiences enhanced practical understanding and provided realistic insight into day-to-day SOC operations.

---

20. Conclusion

This assignment was undertaken with the objective of developing a foundational understanding of Security Operations Center (SOC) concepts while gaining practical exposure to essential monitoring, analysis, and documentation activities.

Through a combination of theoretical study and hands-on lab exercises, core SOC functions such as log analysis, security monitoring, vulnerability assessment, and incident workflow handling were explored. Practical experience with tools including Elastic SIEM, Wireshark, Nessus, Wazuh, and Osquery reinforced how security events are detected, analyzed, and documented in real-world environments.

Despite encountering expected limitations related to permissions, system resources, and lab constraints, the assignment objectives were successfully achieved. These challenges further enhanced understanding of real SOC operational conditions, including role-based access control, tooling dependencies, and environmental limitations.

Overall, this assignment provided a solid foundation in SOC fundamentals and strengthened readiness for advanced SOC learning, deeper incident response exercises, and more complex detection and response scenarios in future work.

Appendix A: Incident Documentation Samples

This appendix contains sample incident documentation created during the assignment to demonstrate the practical application of SOC documentation standards and alignment with industry best practices, including guidance from the SANS Incident Handler's Handbook.
The documents included here serve as supporting evidence of the documentation exercises performed and are referenced in the main report.

A.1 Mock Incident Report – Distributed Denial of Service (DDoS)

Incident Type: Distributed Denial of Service (DDoS)

1. Incident Identification

- **Incident ID:** IR-YYYY-XXX
- **Incident Type:** Distributed Denial of Service (DDoS)
- **Date & Time Detected:**
- **Reported By:** SOC Monitoring / SIEM Alert
- **Affected Asset(s):**
  - Public-facing web server / application
- **Severity Level:** High
- **Incident Status:** Closed

2. Executive Summary

On 02/05/2026, the Security Operations Center identified a Distributed Denial of Service (DDoS) attack targeting a public-facing web service. The attack resulted in temporary service degradation for legitimate users. The incident was detected through abnormal traffic volume

alerts, and mitigation actions were applied using network-level controls. No data breach or system compromise was identified.

3. Incident Detection & Analysis

3.1 Detection Method

- SIEM alert indicating abnormal inbound traffic volume
- Network monitoring tools reporting traffic spikes
- User reports of service unavailability (if applicable)

3.2 Indicators of Compromise (IOCs)

- Sudden increase in inbound requests
- Multiple source IP addresses
- High volume of SYN / HTTP requests

3.3 Attack Classification

- Attack Type: Volumetric / Application-layer DDoS
- Targeted CIA Principle: Availability

4. Incident Scope & Impact Assessment

4.1 Scope

- Web server
- Load balancer (if applicable)

4.2 Impact

- Temporary service disruption
- Increased latency and failed requests
- No evidence of data exfiltration

4.3 Business Impact

- Limited downtime for external users
- No regulatory or data integrity impact

5. Containment Actions

- Rate limiting enabled on network devices
- Malicious IP addresses blocked
- Traffic filtering rules applied
- Coordination with upstream provider (if applicable)

6. Eradication Actions

- Attack traffic removed after stabilization
- Temporary block rules reviewed and cleaned
- Verification that no persistence mechanisms existed

7. Recovery Actions

- Services gradually restored
- System performance monitored post-mitigation
- Traffic levels returned to baseline

8. Post-Incident Activities

8.1 Root Cause Analysis

- Public-facing endpoint lacked sufficient rate limiting
- Limited automated DDoS protection prior to the incident

8.2 Improvements Identified

- Implement permanent rate limiting
- Enable automated DDoS mitigation controls
- Improve alert thresholds for traffic anomalies

8.3 Preventive Measures

- Update incident response playbooks
- Enhance network monitoring visibility
- Conduct periodic DDoS tabletop exercises

9. Timeline of Events

Time	Event

T0	Traffic anomaly detected
T0 + X min	SOC investigation initiated
T0 + X min	Containment actions applied
T0 + X min	Service stabilized
T0 + X min	Incident closed

10. Incident Closure

- **Final Status:** Resolved
- **Data Breach Confirmed:** No
- **Follow-up Required:** No
- **Report Prepared By:**
- **Date Closed:**

Appendix B: Security Event Documentation Samples

This appendix contains sample security event records created to demonstrate how individual security events are documented and tracked within SOC operations.

B.1 Security Event Record – Brute-Force Authentication Attempt

Field	Details
Date / Time	2026-02-05
Source IP	192.168.52.200
Event ID / Type	Brute-Force Login Attempt (Simulated)
Description	Multiple failed SSH login attempts were detected from a single source IP within a short time period. This behavior is consistent with a potential brute-force attack targeting user authentication on the system.

Action Taken	The event was analyzed in Elastic SIEM. The source IP was flagged for monitoring, and no immediate impact was observed. Continued monitoring and alert thresholds were applied.

End of Document